

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>Focal Document: **US - California SB1386 (2002)**Focal Document URL: https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=2001200205B1386Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ca-sb1386-2002.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
SECTION 1	N/A	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
SEC. 2	N/A	Section 1798.29 is added to the Civil Code, to read:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29	N/A	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(a)	N/A	Any agency that owns or licenses computerized data that includes personal information shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure shall be made in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement, as provided in subdivision (c), or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.	Functional	Subset Of	Incident Response Operations	IRO-01	Mechanisms exist to implement and govern processes and documentation to facilitate an organization-wide response capability for cybersecurity and data protection-related incidents.	10	
1798.29(a)	N/A	Any agency that owns or licenses computerized data that includes personal information shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure shall be made in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement, as provided in subdivision (c), or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.	Functional	Intersects With	Incident Handling	IRO-02	Mechanisms exist to cover: (1) Preparation; (2) Automated event detection or manual incident report intake; (3) Analysis; (4) Containment; (5) Eradication; and (6) Recovery.	8	
1798.29(a)	N/A	Any agency that owns or licenses computerized data that includes personal information shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure shall be made in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement, as provided in subdivision (c), or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.	Functional	Intersects With	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	8	
1798.29(a)	N/A	Any agency that owns or licenses computerized data that includes personal information shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure shall be made in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement, as provided in subdivision (c), or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	8	
1798.29(b)	N/A	Any agency that maintains computerized data that includes personal information that the agency does not own shall notify the owner or licensee of the information of any breach of the security of the data immediately following discovery, if the personal information was, or is reasonably believed to have been, acquired by an unauthorized person.	Functional	Intersects With	Cyber Incident Reporting for Sensitive / Regulated Data	IRO-10.2	Mechanisms exist to report sensitive and/or regulated data incidents in a timely manner.	8	
1798.29(c)	N/A	The notification required by this section may be delayed if a law enforcement agency determines that the notification will impede a criminal investigation. The notification required by this section shall be made after the law enforcement agency determines that it will not compromise the investigation.	Functional	Subset Of	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	10	
1798.29(d)	N/A	For purposes of this section, "breach of the security of the system" means unauthorized acquisition of computerized data that compromises the security, confidentiality, or integrity of personal information maintained by the agency. Good faith acquisition of personal information by an employee or agent of the agency for the purposes of the agency is not a breach of the security of the system, provided that the personal information is not used or subject to further unauthorized disclosure.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(e)	N/A	For purposes of this section, "personal information" means an individual's first name or first initial and last name in combination with any one or more of the following data elements, when either the name or the data elements are not encrypted:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(e)(1)	N/A	Social security number.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(e)(2)	N/A	Driver's license number or California Identification Card number.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(e)(3)	N/A	Account number, credit or debit card number, in combination with any required security code, access code, or password that would permit access to an individual's financial account.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(f)	N/A	For purposes of this section, "personal information" does not include publicly available information that is lawfully made available to the general public from federal, state, or local government records.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)	N/A	For purposes of this section, "notice" may be provided by one of the following methods:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(1)	N/A	Written notice.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(2)	N/A	Electronic notice, if the notice provided is consistent with the provisions regarding electronic records and signatures set forth in Section 7001 of Title 15 of the United States Code.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(3)	N/A	Substitute notice, if the agency demonstrates that the cost of providing notice would exceed two hundred fifty thousand dollars (\$250,000), or that the affected class of subject persons to be notified exceeds 500,000, or the agency does not have sufficient contact information. Substitute notice shall consist of all of the following:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(3)(A)	N/A	E-mail notice when the agency has an e-mail address for the subject persons.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(3)(B)	N/A	Conspicuous posting of the notice on the agency's Web site page, if the agency maintains one.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(g)(3)(C)	N/A	Notification to major statewide media.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.29(h)	N/A	Notwithstanding subdivision (g), an agency that maintains its own notification procedures as part of an information security policy for the treatment of personal information and is otherwise consistent with the timing requirements of this part shall be deemed to be in compliance with the notification requirements of this section if it notifies subject persons in accordance with its policies in the event of a breach of security of the system.	Functional	No Relationship	N/A	N/A	N/A	0	
SEC. 3	N/A	Section 1798.82 of the Civil Code is amended and renumbered to read:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.84	N/A	N/A	Functional	No Relationship	N/A	N/A	N/A	0	
1798.84(a)	N/A	Any customer injured by a violation of this title may institute a civil action to recover damages.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.84(b)	N/A	Any business that violates, proposes to violate, or has violated this title may be enjoined.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.84(c)	N/A	The rights and remedies available under this section are cumulative to each other and to any other rights and remedies available under law.	Functional	No Relationship	N/A	N/A	N/A	0	
SEC. 4	N/A	Section 1798.82 is added to the Civil Code, to read:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82	N/A	N/A	Functional	No Relationship	N/A	N/A	N/A	0	

NIST IR 8477-Based Set Theory Relationship Mapping (STRM)

Reference Document: Secure Controls Framework (SCF) version 2026.2

STRM Guidance: <https://securecontrolsframework.com/start-here/set-theory-relationship-mapping-strm/>Focal Document: **US - California SB1386 (2002)**Focal Document URL: https://leginfo.ca.gov/faces/billTextClient.xhtml?bill_id=2001200205B1386Published STRM URL: <https://content.securecontrolsframework.com/strm/scf-strm-usa-state-ca-sb1386-2002.pdf>

FDE #	FDE Name	Focal Document Element (FDE) Description	STRM Rationale	STRM Relationship	SCF Control	SCF #	Secure Controls Framework (SCF) Control Description	Strength of Relationship	Notes
1798.82(a)	N/A	Any person or business that conducts business in California, and that owns or licenses computerized data that includes personal information, shall disclose any breach of the security of the system following discovery or notification of the breach in the security of the data to any resident of California whose unencrypted personal information was, or is reasonably believed to have been, acquired by an unauthorized person. The disclosure shall be made in the most expedient time possible and without unreasonable delay, consistent with the legitimate needs of law enforcement, as provided in subdivision (c), or any measures necessary to determine the scope of the breach and restore the reasonable integrity of the data system.	Functional	Subset Of	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	10	
1798.82(b)	N/A	Any person or business that maintains computerized data that includes personal information that the person or business does not own shall notify the owner or licensee of the information of any breach of the security of the data immediately following discovery, if the personal information was, or is reasonably believed to have been, acquired by an unauthorized person.	Functional	Subset Of	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	10	
1798.82(c)	N/A	The notification required by this section may be delayed if a law enforcement agency determines that the notification will impede a criminal investigation. The notification required by this section shall be made after the law enforcement agency determines that it will not compromise the investigation.	Functional	Subset Of	Incident Stakeholder Reporting	IRO-10	Mechanisms exist to timely-report incidents to applicable: (1) Internal stakeholders; (2) Affected clients & third-parties; and (3) Regulatory authorities.	10	
1798.82(d)	N/A	For purposes of this section, "breach of the security of the system" means unauthorized acquisition of computerized data that compromises the security, confidentiality, or integrity of personal information maintained by the person or business. Good faith acquisition of personal information by an employee or agent of the person or business for the purposes of the person or business is not a breach of the security of the system, provided that the personal information is not used or subject to further unauthorized disclosure.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(e)	N/A	For purposes of this section, "personal information" means an individual's first name or first initial and last name in combination with any one or more of the following data elements, when either the name or the data elements are not encrypted:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(e)(1)	N/A	Social security number.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(e)(2)	N/A	Driver's license number or California Identification Card number.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(e)(3)	N/A	Account number, credit or debit card number, in combination with any required security code, access code, or password that would permit access to an individual's financial account.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(f)	N/A	For purposes of this section, "personal information" does not include publicly available information that is lawfully made available to the general public from federal, state, or local government records.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)	N/A	For purposes of this section, "notice" may be provided by one of the following methods:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(1)	N/A	Written notice.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(2)	N/A	Electronic notice, if the notice provided is consistent with the provisions regarding electronic records and signatures set forth in Section 7001 of Title 15 of the United States Code.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(3)	N/A	Substitute notice, if the person or business demonstrates that the cost of providing notice would exceed two hundred fifty thousand dollars (\$250,000), or that the affected class of subject persons to be notified exceeds 500,000, or the person or business does not have sufficient contact information. Substitute notice shall consist of all of the following:	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(3)(A)	N/A	E-mail notice when the person or business has an e-mail address for the subject persons.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(3)(B)	N/A	Conspicuous posting of the notice on the Web site page of the person or business, if the person or business maintains one.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(g)(3)(C)	N/A	Conspicuous posting of the notice on the Web site page of the person or business, if the person or business maintains one.	Functional	No Relationship	N/A	N/A	N/A	0	
1798.82(h)	N/A	Notwithstanding subdivision (g), a person or business that maintains its own notification procedures as part of an information security policy for the treatment of personal information and is otherwise consistent with the timing requirements of this part, shall be deemed to be in compliance with the notification requirements of this section if the person or business notifies subject persons in accordance with its policies in the event of a breach of security of the system.	Functional	No Relationship	N/A	N/A	N/A	0	
SEC. 5	N/A	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	
SEC. 6	N/A	See FDE for details.	Functional	No Relationship	N/A	N/A	N/A	0	